USO INTERNO — LABORATORIO PERSONALE

exa-dune

Framework Multi-Protocollo per Penetration Testing

Versione 2.5.0 — Marzo 2026

Manuale operativo completo per l'utilizzo di exa-dune in ambienti IoT e VoIP. Questo documento copre tutte le funzionalità della versione 2.5.0, incluso il sistema di pipeline automatizzata, le wordlist integrate, il modulo ONVIF, l'installer automatico, i report HTML/PDF professionali con copia automatica su Desktop, e molto altro. Progettato per essere accessibile anche ai principianti.

30	24	25+	5
SUBCOMANDI	WORDLIST DISPONIBILI	PORTE MAPPATE	FASI PIPELINE

Autore: Security Lab — Piattaforma: Kali Linux 6.18

⚠ CONFIDENZIALE — USO ESCLUSIVAMENTE IN AMBIENTI AUTORIZZATI ⚠

Indice dei Contenuti

1. Introduzione e Concetti Base 3

2. Installazione e Configurazione 5

3. Architettura del Tool 7

4. Flag Globali e Opzioni Comuni 9

5. Wordlist Integrate 11

6. Subcomandi di Scansione e Ricognizione 13

- 6.1 scan — Scansione di Rete 13
- 6.2 dns — Enumerazione DNS 15
- 6.3 web — Audit Web/HTTP 16
- 6.4 http — Analisi Header HTTP 18
- 6.5 ssl — Analisi Certificati TLS 19

7. Subcomandi VoIP e Multimedia 20

- 7.1 sip — Enumerazione SIP 20
- 7.2 rtsp — Streaming RTSP 22

8. Subcomandi Brute-Force e Credenziali 24

- 8.1 ssh — Brute Force SSH 24
- 8.2 ftp — Brute Force FTP 25
- 8.3 telnet — Brute Force Telnet 26

8.4 creds — Credenziali IoT/VoIP 27

8.5 rdp — Remote Desktop Protocol 28

8.6 vnc — Virtual Network Computing 29

8.7 smb — Condivisioni SMB/CIFS 30

9. Subcomandi Protocolli Industriali/IoT 31

9.1 snmp — Simple Network Management Protocol 31

9.2 mqtt — Message Queuing 33

9.3 modbus — Protocollo Industriale 34

9.4 redis — Database Redis 35

9.5 ldap — Servizi LDAP 36

9.6 upnp — Universal Plug and Play 37

9.7 tftp — Trivial File Transfer 38

9.8 coap — IoT CoAP Protocol 39

9.9 ipmi — Server Management 40

10. Subcomandi Avanzati 41

10.1 js — Analisi JavaScript 41

10.2 fw — Firmware Analysis 42

10.3 post — Post-Exploitation 43

10.4 auto — Automazione 45

10.5 report — Generazione Report 46

10.6 onvif — Telecamere ONVIF 47

10.7 install — Installazione Tool 48

10.8 wordlists — Download Wordlist 49

10.9 Nuovi Subcomandi IoT/OT v2.5.0 50

11. Pipeline Automatizzata 57

12. Scenari Pratici di Laboratorio 55

13. Glossario per Principianti 61

14. Cheat Sheet Rapido 65

15. Changelog e Versioni 68

1. Introduzione e Concetti Base

1.1 Cos'è exa-dune?

exa-dune è un framework di penetration testing scritto in Bash, progettato specificamente per ambienti **IoT** (Internet of Things) e **VoIP** (Voice over IP). È uno strumento a riga di comando che integra e coordina numerosi tool di sicurezza già presenti su Kali Linux, presentandoli attraverso un'interfaccia unificata e semplice.

> **COS'È IL PENETRATION TESTING?**
>
> Il penetration testing (o "pentest") è il processo autorizzato di testare la sicurezza di un sistema informatico simulando gli attacchi di un hacker reale. L'obiettivo è trovare le vulnerabilità prima che lo facciano i malintenzionati, per poi poterle correggere.

1.2 Cosa può fare exa-dune?

- **Scansione di rete** — Trova dispositivi attivi, porte aperte e servizi esposti
- **Brute-force delle credenziali** — Testa username e password su molti protocolli
- **Audit di protocolli specifici** — SIP/VoIP, SNMP, MQTT, Modbus, RTSP e altri
- **Analisi web** — Trova directory nascoste, vulnerabilità LFI, header mancanti
- **Analisi firmware** — Estrae e analizza firmware di dispositivi IoT
- **Pipeline automatizzata** — Esegue scan → analisi → attacchi → report in sequenza
- **Generazione report PDF** — Produce report professionali pronti per la documentazione

1.3 Concetti Fondamentali

Porta di Rete

Una **porta** è come una "porta d'ingresso" virtuale su un dispositivo di rete. Ogni servizio usa una porta specifica: il web usa la porta 80 (HTTP) o 443 (HTTPS), SSH usa la 22, VoIP/SIP usa la 5060. Esistono 65535 porte; alcune sono standardizzate, altre usate liberamente dai produttori.

Protocollo

Un **protocollo** è il "linguaggio" che due dispositivi usano per comunicare. SSH è un protocollo sicuro per accesso remoto; SIP è il protocollo per le telefonate VoIP; SNMP serve a gestire dispositivi di rete da remoto.

Brute Force

Il **brute force** consiste nel provare molte combinazioni di username e password fino a trovare quella corretta. È efficace quando si usano password deboli o di default (come "admin/admin"). exa-dune include oltre 119 password e 43 username pre-integrati.

Wordlist

Una **wordlist** è una lista di parole (username, password, percorsi web, community string) usata durante gli attacchi automatizzati. exa-dune v2.5.0 include 7 wordlist integrate direttamente nel codice, quindi funziona anche senza SecLists installato.

> **AVVISO LEGALE**
>
> exa-dune deve essere utilizzato **esclusivamente** su sistemi di cui si è proprietari o per cui si ha un'esplicita autorizzazione scritta. L'uso non autorizzato è illegale in Italia (art. 615-ter, 617-quater, 640-ter c.p.) e nella maggior parte dei paesi. Questo strumento è destinato a laboratori personali isolati.

1.4 Architettura del Laboratorio Supportata

RETE	SCOPO	DISPOSITIVI TIPICI

`192.168.1.0/24`	Rete principale lab	VoIP phones, gateway, telecamere
`192.168.2.0/24`	Rete secondaria lab	IoT sensors, switch, access point
`192.168.x.100`	Kali Linux (attaccante)	Macchina con exa-dune

2. Installazione e Configurazione

2.1 Requisiti di Sistema

COMPONENTE	REQUISITO	NOTE
Sistema Operativo	Kali Linux (consigliato)	Tutte le dipendenze pre-installate
Shell	Bash 4.4+	Richiede array associativi
Privilegi	root	Necessario per scansioni raw socket
RAM	512 MB min	2 GB consigliati per pipeline completa
Disco	1 GB libero	Per output scan e report

2.2 Dipendenze

exa-dune utilizza automaticamente i tool disponibili su Kali Linux:

TOOL	FUNZIONE	PROTOCOLLO
`nmap`	Scansione porte e rilevamento servizi	TCP/UDP
`hydra`	Brute force credenziali	SSH, FTP, HTTP, SIP…
`svmap` / `svwar` / `svcrack`	Enumerazione e attacco SIP	SIP/VoIP
	Lettura MIB SNMP	SNMP

`snmpwalk / snmpbulkwalk`		
`mosquitto_sub / mosquitto_pub`	Client MQTT	MQTT
`nikto`	Scanner vulnerabilità web	HTTP/HTTPS
`ffuf / gobuster`	Directory/path fuzzing	HTTP
`openssl / testssl.sh`	Analisi certificati TLS	TLS/SSL
`binwalk`	Analisi e estrazione firmware	Binario
`weasyprint`	Conversione HTML→PDF	—

2.3 Installazione

```
# 1. Copia lo script nella directory di lavoro
cp exa-dune /root/pentest/exa-dune

# 2. Rendi eseguibile
chmod +x /root/pentest/exa-dune

# 3. (Opzionale) Aggiungi al PATH per usarlo ovunque
echo 'export PATH="$PATH:/root/pentest"' >> ~/.zshrc
source ~/.zshrc

# 4. Verifica installazione
exa-dune --version
# Output: exa-dune v2.5.0

# 5. Verifica dipendenze PDF
which weasyprint
# /usr/bin/weasyprint
```

2.4 Prima Esecuzione

```
# Visualizza aiuto generale
exa-dune --help

# Testa con dry-run (nessuna azione reale)
exa-dune scan --target 192.168.1.0/24 --dry-run

# Verifica che le wordlist integrate funzionino
exa-dune creds --target 192.168.1.1 --dry-run
```

2.5 Directory di Output

Per convenzione, tutti gli output vanno in sottodirectory con timestamp:

```
/root/pentest/
├── exa-dune            # Script principale
├── scans/              # Output nmap (.nmap, .xml, .gnmap)
│   └── scan_20260321_143022/
├── reports/            # Report HTML e PDF
│   └── REPORT_20260321_143500.pdf
└── scripts/            # Script ausiliari
```

SUGGERIMENTO

Crea sempre una directory di output dedicata con `mkdir -p /root/pentest/scans` prima di iniziare un'engagement. Questo mantiene ordinato il filesystem e facilita la generazione dei report.

3. Architettura del Tool

3.1 Struttura dei Comandi

Ogni invocazione di exa-dune segue questa struttura:

```
exa-dune <subcomando> [flag globali] [flag specifici] [argomenti]
```

Esempio:

```
exa-dune ssh --target 192.168.1.50 --user root --output-dir /root/pentest/scans
```

3.2 I 29 Subcomandi

CATEGORIA	SUBCOMANDO	FUNZIONE
Ricognizione	`scan`	Scansione porte con nmap
	`dns`	Enumerazione sottodomini e DNS
	`web`	Directory fuzzing e audit web
	`http`	Analisi header HTTP/sicurezza
	`ssl`	Analisi certificati TLS/SSL
VoIP	`sip`	Enumerazione SIP, registrazioni, crack
	`rtsp`	Scansione stream RTSP (telecamere)
Brute Force	`ssh`	Brute force SSH
	`ftp`	Brute force FTP
	`telnet`	Brute force Telnet

	`creds`	Default credentials IoT/VoIP
	`rdp`	Brute force Remote Desktop
	`vnc`	Brute force VNC
	`smb`	Enumerazione e brute SMB
Protocolli IoT	`snmp`	Community brute, MIB walk
	`mqtt`	Subscribe/publish MQTT
	`modbus`	Lettura registri Modbus/TCP
	`redis`	Accesso Redis non autenticato
	`ldap`	Enumerazione LDAP
	`upnp`	Discovery UPnP
	`tftp`	Download file via TFTP
	`coap`	GET risorse CoAP
	`ipmi`	Dump hash IPMI/BMC
Avanzati	`js`	Analisi JavaScript per segreti
	`fw`	Analisi firmware binari
	`post`	Post-exploitation
	`auto`	Automazione multi-target
	`report`	Generazione report PDF
	`pipeline`	Pipeline scan→attacco→report

3.3 Flusso di Esecuzione

Target → scan → Suggerimenti → Attacchi →

Post-Exploit → report PDF

Con il subcomando `pipeline`, questo flusso viene eseguito automaticamente con un singolo comando.

4. Flag Globali e Opzioni Comuni

I flag globali possono essere usati con **qualsiasi** subcomando di exa-dune.

FLAG	VALORE	DESCRIZIONE
`--target / -t`	IP / CIDR / hostname	Target dell'operazione (obbligatorio nella maggior parte dei comandi)
`--output-dir / -o`	percorso directory	Directory dove salvare tutti gli output. Viene creata se non esiste.
`--verbose / -v`	—	Mostra output dettagliato di tutti i comandi eseguiti
`--dry-run`	—	Simula l'esecuzione senza eseguire azioni reali. Mostra solo i comandi che verrebbero eseguiti.
`--stealth`	—	Modalità silenziosa: scan più lento (T2), pacchetti ridotti, meno log. Riduce visibilità su IDS/IPS.
`--timeout`	secondi	Timeout massimo per ogni operazione (default: 300s)
`--port / -p`	numero porta	Specifica porta non standard per il servizio target
`--user / -u`	username	Username singolo per brute force (invece della wordlist)
`--pass / -P`	password	Password singola per brute force (invece della wordlist)
`--user-list`	file	File wordlist utenti personalizzato

`--pass-list`	file	File wordlist password personalizzato
`--threads`	numero	Thread paralleli per brute force (default: 4)
`--version`	—	Mostra versione di exa-dune ed esce
`--help / -h`	—	Mostra aiuto per il subcomando corrente

4.1 Esempi di Flag Combinati

```
# Brute force SSH silenzioso, output su disco, 8 thread
exa-dune ssh --target 192.168.1.50 \
         --stealth \
         --threads 8 \
         --output-dir /root/pentest/scans \
         --verbose

# Test credenziale specifica senza brute force
exa-dune ssh --target 192.168.1.50 \
         --user admin \
         --pass admin1234

# Dry run: vedi cosa farebbe senza eseguire
exa-dune web --target 192.168.1.100 --dry-run --verbose
```

4.2 Codici di Uscita

CODICE	SIGNIFICATO
`0`	Successo — operazione completata senza errori
`1`	Errore generico — argomenti mancanti o tool non disponibile
`2`	Target non raggiungibile

3	Nessun risultato trovato (es. brute force fallito)

5. Wordlist Integrate

exa-dune v2.5.0 include 7 categorie di wordlist direttamente nel codice sorgente (embedded), più 24 wordlist aggiuntive da SecLists disponibili via `exa-dune wordlists`. Questo significa che il tool è **completamente autosufficiente**: funziona anche senza SecLists installato. Le wordlist esterne (se presenti) vengono comunque preferite perché più complete.

5.1 Gerarchia di Fallback

Per ogni tipo di wordlist, exa-dune cerca in questo ordine:

```
1. File personalizzato (--user-list / --pass-list / flag specifico)
2. SecLists su /usr/share/seclists/
3. Wordlist Kali predefinite (/usr/share/wordlists/)
4. → Wordlist integrata nel tool (sempre disponibile)
```

5.2 Le 7 Wordlist Integrate

FUNZIONE	VOCE	CONTENUTO	FONTE BASE
`_wl_users()`	43 username	admin, root, user, guest, voip, sip, ubnt, cisco, pi…	SecLists top-usernames + IoT-specifici
`_wl_pass()`	119 password	admin, password, 123456, Admin1234, 7ujMko0admin, raspberry…	SecLists best110 + pattern IoT/VoIP
`_wl_web()`	70 percorsi	/admin, /cgi-bin/, /api/, /config, /	dirb + percorsi CGI VoIP/camera

		firmware, /stream…	
`_wl_snmp()`	70 community	public, private, community, cisco, manager, ilmi…	SecLists SNMP + vendor-specifici
`_wl_lfi()`	29 payload LFI	../etc/passwd, ../../etc/shadow, /proc/version…	Path traversal comuni
`_wl_dns()`	57 sottodomini	www, mail, admin, voip, sip, api, dev, staging…	SecLists subdomains-top1mil (estratto)
`_wl_iot_creds()`	65 coppie user:pass	admin:admin, ubnt:ubnt, root:vizxv, pi:raspberry…	Default credentials vendor IoT/VoIP

5.3 Wordlist IoT/VoIP Dettaglio

La wordlist `_wl_iot_creds()` copre le credenziali di default dei principali vendor:

VENDOR / DISPOSITIVO	USERNAME	PASSWORD
Generico	admin	admin, password, 1234, (vuota)
Ubiquiti (UniFi, AirOS)	ubnt	ubnt
Raspberry Pi	pi	raspberry
Mirai botnet targets	root	vizxv, xc3511, 888888, 666666
APC UPS	apc	apc
Cisco	cisco	cisco, (vuota)
Huawei	root	admin, huawei, Huawei12#$

AudioCodes	Admin	Admin, admin
Generic VoIP	voip, sip	voip, sip, 1234
Supervisor	supervisor	supervisor, (vuota)

SUGGERIMENTO — WORDLIST PERSONALIZZATE

Per massimizzare l'efficacia del brute force, usa `--pass-list` con le wordlist complete di SecLists: `/usr/share/seclists/Passwords/xato-net-10-million-passwords-100000.txt` contiene 100.000 password reali da data breach.

6. Subcomandi di Scansione e Ricognizione

scan

Scansione porte e servizi con nmap — punto di partenza per ogni engagement

Cos'è una scansione di porte?

Quando exa-dune "scansiona" un target, invia pacchetti TCP/UDP a ogni porta (da 1 a 65535) e analizza la risposta. Se la porta risponde, il servizio è attivo. nmap (il tool usato internamente) è in grado di rilevare anche **quale software** gira su quella porta e la sua versione, informazione fondamentale per trovare vulnerabilità note (CVE).

Sintassi

```
exa-dune scan --target TARGET [opzioni]
```

Flag Specifici

FLAG	DEFAULT	DESCRIZIONE
`--ports / -p`	top-1000	Porte da scansionare (es: 80,443,8080 oppure 1-65535)
`--scan-type`	SV	Tipo scan: SV (version), A (aggressive), sU (UDP)
`--script`	—	NSE script nmap aggiuntivi (es: vuln, auth, banner)
`--timing / -T`	T4	Velocità: T1(lento)–T5(veloce). T4 default, T2 con --stealth

`--top-ports`	—	Scansiona solo le N porte più comuni (es: --top-ports 100)
`--udp`	—	Aggiunge scansione UDP (richiede root, molto più lenta)
`--ping-sweep`	—	Solo ping, non scansione porte (rapido discovery)

Esempi Pratici

```
# Scan base di una sottorete (trova tutti gli host)
exa-dune scan --target 192.168.1.0/24 --output-dir /root/pentest/scans

# Scan aggressivo su singolo IP (rileva OS, versioni, script)
exa-dune scan --target 192.168.1.50 --scan-type A --output-dir /root/pentest/

# Scan furtivo (lento, evita IDS)
exa-dune scan --target 192.168.1.50 --stealth --output-dir /root/pentest/scan

# Scan solo porte VoIP/SIP
exa-dune scan --target 192.168.1.0/24 --ports 5060,5061,5080,1720,4569

# Scan UDP per SNMP e TFTP
exa-dune scan --target 192.168.1.50 --udp --ports 161,69,123,514
```

Output Generati

FILE	FORMATO	UTILIZZO
`scan_TARGET_TIMESTAMP.nmap`	Testo leggibile	Revisione manuale rapida
`scan_TARGET_TIMESTAMP.xml`	XML strutturato	Import in altri tool (Metasploit, ecc.)
`scan_TARGET_TIMESTAMP.gnmap`	Greppable	Parsing automatico

		da exa-dune pipeline

Funzionalità v2.5.0 — Auto-Suggerimenti

Al termine di ogni scan, exa-dune v2.4.0 **analizza automaticamente i risultati** e suggerisce quali attacchi eseguire in base alle porte aperte rilevate:

```
[+] Scan completato. Porte aperte rilevate: 22, 80, 5060, 8443

[!] SUGGERIMENTI ATTACCHI (ordine di priorità):
 [P1] sip      --target 192.168.1.50 --port 5060    → SIP esposto: enum utent
 [P5] ssh      --target 192.168.1.50                → SSH: brute force creden
 [P8] web      --target 192.168.1.50 --port 80      → HTTP: directory fuzzing
 [P9] web      --target 192.168.1.50 --port 8443    → HTTPS: directory fuzzin

[+] Esegui pipeline per automatizzare tutti gli attacchi:
    exa-dune pipeline --from-scan /root/pentest/scans/scan_20260321/ --auto
```

dns

Enumerazione DNS — trova sottodomini e record di un dominio

Cos'è l'enumerazione DNS?

Il DNS (Domain Name System) traduce nomi come `voip.azienda.local` in indirizzi IP. Enumerare il DNS significa scoprire tutti i sottodomini e i record esistenti, rivelando servizi nascosti che potrebbero non essere visibili dalla scansione di rete diretta.

Flag Specifici

FLAG	DESCRIZIONE
`--domain`	Dominio da enumerare (es: azienda.local)
`--dns-server`	Server DNS da interrogare (default: resolver di sistema)
`--wordlist`	Wordlist sottodomini personalizzata
`--axfr`	Tenta zone transfer (AXFR) — rivela tutti i record se abilitato
`--brute`	Abilita brute force sottodomini con wordlist integrata (57 voci)

```
# Enumerazione base con zone transfer
exa-dune dns --target 192.168.1.1 --domain lab.local --axfr

# Brute force sottodomini con wordlist integrata
exa-dune dns --target 192.168.1.1 --domain lab.local --brute

# Usa server DNS specifico
exa-dune dns --target 192.168.1.1 --domain lab.local --dns-server 192.168.1.1
```

ZONE TRANSFER (AXFR)

Un **zone transfer** è una funzionalità del protocollo DNS che permette di copiare tutti i record di un dominio da un server all'altro. Se il server DNS è mal configurato e accetta richieste AXFR da qualsiasi host, rivela l'intera mappa della rete interna. Questo è un problema comune nei laboratori e nelle reti aziendali non aggiornate.

web

Audit web — directory fuzzing, LFI, analisi vulnerabilità HTTP

Cos'è il fuzzing web?

Il **fuzzing** consiste nel provare sistematicamente molti percorsi URL per trovare risorse nascoste: pannelli di amministrazione, API non documentate, file di configurazione, directory con listing abilitato. Molti dispositivi IoT/VoIP espongono percorsi CGI sensibili come `/cgi-bin/upgrade.cgi` o `/admin/config.html`.

Flag Specifici

FLAG	DESCRIZIONE
`--port`	Porta HTTP/HTTPS (default: 80)
`--https`	Usa HTTPS invece di HTTP
`--wordlist`	Wordlist percorsi web personalizzata
`--nikto`	Esegue scan nikto dopo il fuzzing
`--lfi`	Abilita test LFI (Local File Inclusion) con 29 payload integrati
`--auth`	Credenziali HTTP Basic Auth (formato user:pass)
`--extensions`	Estensioni da testare (es: php,html,cgi,asp)
`--follow-redirect`	Segui i redirect HTTP

```
# Fuzzing base con wordlist integrata (70 percorsi)
exa-dune web --target 192.168.1.50 --port 80

# HTTPS con test LFI e nikto
exa-dune web --target 192.168.1.50 --port 8443 --https --lfi --nikto

# Autenticazione base con wordlist estesa
```

```
exa-dune web --target 192.168.1.50 \
          --auth admin:admin \
          --wordlist /usr/share/wordlists/dirb/common.txt
```

Percorsi Chiave per Dispositivi VoIP/IoT

PERCORSO	DISPOSITIVO TIPICO	CONTENUTO
`/cgi-bin/status.cgi`	AudioCodes MP20x	Status sistema, configurazione
`/cgi-bin/upgrade.cgi`	Gateway VoIP generico	Upload firmware
`/api/v1/config`	Telecamere IP moderne	Configurazione JSON
`/axis-cgi/`	Axis IP Cameras	API proprietaria Axis
`/admin/`	Tutti	Pannello amministrazione
`/config.xml`	Gateway SIP	Configurazione XML (spesso non protetta)
`/firmware.bin`	Router/IoT	Firmware scaricabile direttamente

http Analisi header HTTP e sicurezza del server web

Analizza gli header HTTP di risposta per identificare configurazioni di sicurezza mancanti (CSP, HSTS, X-Frame-Options), informazioni di versione esposte (Server, X-Powered-By) e altri problemi di configurazione comuni.

```
# Analisi header di un pannello web
exa-dune http --target 192.168.1.50 --port 80

# Output tipico
[+] Server: nginx/1.14.0            # Versione esposta → cerca CVE
[-] X-Frame-Options: MANCANTE        # Vulnerabile a clickjacking
[-] Content-Security-Policy: MANCANTE
[-] HSTS: MANCANTE                  # HTTP non forzato a HTTPS
[+] X-Content-Type-Options: nosniff
```

ssl Analisi certificati TLS/SSL e cypher suite

Verifica la configurazione TLS del server: versioni supportate (TLS 1.0/1.1 deprecate), cipher suite deboli, certificati scaduti o autofirmati, vulnerabilità come POODLE, BEAST, HEARTBLEED, e supporto per algoritmi obsoleti (RC4, DES, MD5).

```
# Analisi SSL/TLS con testssl.sh
exa-dune ssl --target 192.168.1.50 --port 443

# Output tipico per gateway VoIP
[-] TLS 1.0: ABILITATO (deprecato)
[-] TLS 1.1: ABILITATO (deprecato)
[+] TLS 1.2: ABILITATO
[-] Certificato: AUTOFIRMATO
[-] Cipher: RC4 SUPPORTATO (debole)
[-] HEARTBLEED: VULNERABILE
```

7. Subcomandi VoIP e Multimedia

`sip` Enumerazione SIP, discovery utenti, crack PIN — protocollo VoIP principale

Cos'è il protocollo SIP?

SIP (Session Initiation Protocol) è il protocollo standard per le telefonate VoIP. Funziona sulla porta **5060/UDP** (o TCP) e **5061/TCP** per SIP-TLS. Ogni telefono VoIP, gateway, PBX (centralino) e softphone usa SIP. Il protocollo gestisce la segnalazione: avvio, modifica e chiusura delle chiamate.

Un server SIP espone **account/estensioni** (es: 100, 101, 200) protetti da PIN. L'enumerazione SIP scopre quali estensioni esistono; il cracking testa i PIN comuni.

Flag Specifici

FLAG	DEFAULT	DESCRIZIONE
`--port`	5060	Porta SIP (5060=UDP/TCP, 5061=TLS)
`--transport`	udp	Protocollo: udp, tcp, tls
`--enum`	—	Enumera estensioni/utenti (usa svwar)
`--crack`	—	Tenta cracking PIN (usa svcrack)
`--extension-range`	100-999	Range estensioni da enumerare

`--method`	REGISTER	Metodo SIP: REGISTER, OPTIONS, INVITE
`--user-agent`	exa-dune	User-Agent SIP personalizzato
`--domain`	IP target	Dominio SIP (realm)

Esempi Pratici

```
# Discovery: verifica se il server risponde a SIP OPTIONS
exa-dune sip --target 192.168.1.50

# Enumerazione estensioni 100-500
exa-dune sip --target 192.168.1.50 --enum --extension-range 100-500

# Cracking PIN su estensione specifica
exa-dune sip --target 192.168.1.50 --crack --user 200

# SIP su TCP (AudioCodes spesso usa TCP)
exa-dune sip --target 192.168.1.50 --transport tcp --enum

# SIP-TLS (porta 5061)
exa-dune sip --target 192.168.1.50 --port 5061 --transport tls
```

Interpretare i Risultati

```
[+] SIP OPTIONS: 200 OK                # Server risponde
[+] Extension 100: FOUND (401 Auth)    # Estensione esiste, richiede auth
[+] Extension 101: FOUND (401 Auth)
[-] Extension 102: NOT FOUND (404)     # Estensione non esiste
[+] CRACK: 100:1234 SUCCESS!           # PIN trovato!
```

Dispositivi nel Lab

DISPOSITIVO	IP	PORTA SIP	NOTE
AudioCodes MP202/205	192.168.1.x	5060/ UDP	Gateway analogico→VoIP.

			Espone estensioni FXS.
Commend ET962-BF5xx	192.168.1.x	5060/UDP	Stazione citofonico SIP. Default creds spesso factory.
GAI-Tronics Commander VoIP	192.168.1.x	5060/UDP	Telefono industriale. Pannello web su 80/443.

Scenario: AudioCodes MP202 `192.168.1.50`

```
# 1. Verifica che SIP sia attivo
exa-dune sip --target 192.168.1.50

# 2. Enumera estensioni (MP202 spesso usa 1-4 porte FXS)
exa-dune sip --target 192.168.1.50 --enum --extension-range 1-20

# 3. Crack PIN con lista comune
exa-dune sip --target 192.168.1.50 --crack --user 1

# 4. Controlla anche il pannello web admin
exa-dune web --target 192.168.1.50 --port 8080
```

rtsp Scansione stream RTSP — accesso a telecamere IP e videocitofoni

Cos'è RTSP?

RTSP (Real Time Streaming Protocol) è il protocollo usato dalle telecamere IP per trasmettere video in streaming. Funziona tipicamente sulla porta **554/TCP**. Molte telecamere espongono gli stream senza autenticazione o con credenziali di default.

Flag Specifici

FLAG	DESCRIZIONE
`--port`	Porta RTSP (default: 554)
`--path`	Percorso stream RTSP specifico (es: /stream1, /live)
`--brute-path`	Testa percorsi RTSP comuni (wordlist integrata)
`--snapshot`	Cattura snapshot (richiede ffmpeg)

```
# Discovery stream RTSP
exa-dune rtsp --target 192.168.1.100

# Brute force percorsi stream su telecamera Axis
exa-dune rtsp --target 192.168.1.100 --brute-path

# URL RTSP tipici per Axis
# rtsp://192.168.1.100/axis-media/media.amp
# rtsp://192.168.1.100/mpeg4/media.amp
```

PERCORSI RTSP COMUNI

- Axis: `/axis-media/media.amp`
- Hikvision: `/Streaming/Channels/101`
- Dahua: `/cam/realmonitor?channel=1&subtype=0`

- Generico: `/stream1`, `/live/ch00_0`, `/video1`

8. Subcomandi Brute-Force e Credenziali

COME FUNZIONA IL BRUTE FORCE IN EXA-DUNE

Tutti i comandi di brute force usano **hydra** internamente. hydra prova ogni combinazione username/password dalla wordlist e riporta le credenziali valide. La velocità dipende dal numero di thread (`--threads`). Con `--stealth` si usa 1 thread e si aggiungono delay per eludere i sistemi di rilevamento.

ssh

Brute force SSH — accesso remoto sicuro alla shell

SSH (Secure Shell) è il protocollo standard per accesso remoto sicuro. Porta default: **22/TCP**. Molti dispositivi IoT/VoIP hanno SSH abilitato con credenziali di default o deboli.

```
# Brute force con wordlist integrate
exa-dune ssh --target 192.168.1.50 --output-dir /root/pentest/scans

# Test credenziali specifiche
exa-dune ssh --target 192.168.1.50 --user root --pass admin

# Wordlist personalizzata, 8 thread
exa-dune ssh --target 192.168.1.50 \
         --user-list /usr/share/seclists/Usernames/top-usernames-shortlist.tx
         --pass-list /usr/share/seclists/Passwords/xato-net-10-million-passwo
         --threads 8

# Output di successo
[+] FOUND: root:admin @ 192.168.1.50:22
[+] Credenziali salvate in: /root/pentest/scans/ssh_creds.txt
```

ftp

Brute force FTP — file transfer non cifrato

FTP (File Transfer Protocol) porta **21/TCP**. Non cifra i dati — credenziali in chiaro. Molti dispositivi embedded usano FTP per aggiornamenti firmware o backup configurazione.

```
# Brute force FTP + test anonymous login
exa-dune ftp --target 192.168.1.50

# Test solo accesso anonimo
exa-dune ftp --target 192.168.1.50 --user anonymous --pass anonymous
```

telnet

Brute force Telnet — protocollo legacy non cifrato

Telnet (porta **23/TCP**) è il precursore di SSH: accesso remoto ma senza cifratura. Ancora molto comune su dispositivi IoT/embedded economici e hardware industriale legacy.

```
# Brute force Telnet
exa-dune telnet --target 192.168.1.50

# Porta non standard
exa-dune telnet --target 192.168.1.50 --port 2323
```

ATTENZIONE

Telnet trasmette username e password in chiaro. Se sei su una rete condivisa, le credenziali possono essere catturate con Wireshark da qualsiasi altro host. Considera sempre tcpdump/Wireshark per intercettare il traffico durante i test.

creds

Test credenziali di default IoT/VoIP su tutti i protocolli

Il subcomando `creds` è specializzato per dispositivi IoT/VoIP: usa la wordlist integrata `_wl_iot_creds()` con 65 coppie user:pass specifiche per vendor, e le testa automaticamente su tutti i protocolli rilevati (SSH, Telnet, FTP, HTTP, SIP).

```
# Test tutte le credenziali IoT su tutti i protocolli
exa-dune creds --target 192.168.1.50

# Solo HTTP con credenziali vendor-specifiche
exa-dune creds --target 192.168.1.50 --port 80 --protocol http

# Output tipico
[+] HTTP 192.168.1.50:80 Admin:Admin → 200 OK
[+] Credenziali valide trovate!
```

rdp

Brute force RDP — Remote Desktop Protocol (Windows)

RDP (porta **3389/TCP**) permette il controllo grafico remoto di sistemi Windows. Raro sui dispositivi VoIP puri, ma presente su PC embedded con software gestione VoIP.

```
# Brute force RDP
exa-dune rdp --target 192.168.1.50 --output-dir /root/pentest/scans
```

vnc

Brute force VNC — accesso desktop remoto multipiattaforma

VNC (porta **5900/TCP**) è un sistema di controllo remoto grafico. Comune su dispositivi embedded Linux e alcuni apparati di rete con interfaccia grafica.

```
# Brute force VNC
exa-dune vnc --target 192.168.1.50
```

smb

Enumerazione e brute force SMB — condivisioni file Windows/Samba

SMB (Server Message Block, porta **445/TCP**) è usato per condivisioni file Windows e Samba su Linux. Vulnerabilità storiche: EternalBlue (MS17-010), WannaCry, NotPetya.

```
# Enumerazione condivisioni (null session)
exa-dune smb --target 192.168.1.50

# Brute force + enum condivisioni
exa-dune smb --target 192.168.1.50 --brute

# Test vulnerabilità EternalBlue
exa-dune smb --target 192.168.1.50 --script vuln
```

9. Subcomandi Protocolli Industriali/IoT

`snmp`

SNMP community brute force e MIB walk — gestione dispositivi di rete

Cos'è SNMP?

SNMP (Simple Network Management Protocol) è il protocollo usato per monitorare e gestire dispositivi di rete (router, switch, VoIP gateway, UPS). Funziona su porta **161/UDP**. L'accesso è controllato da una **community string** (simile a una password). Le community di default sono `public` (lettura) e `private` (scrittura).

Con la community string corretta, è possibile leggere la **MIB** (Management Information Base): un albero di informazioni sul dispositivo che include configurazione, routing table, utenti, interfacce di rete e persino le password in testo chiaro su alcuni dispositivi legacy.

Flag Specifici

FLAG	DEFAULT	DESCRIZIONE
`--port`	161	Porta SNMP UDP
`--version`	2c	Versione SNMP: 1, 2c, 3
`--community`	—	Community string specifica da testare
`--community-list`	—	File community strings personalizzato
`--walk`	—	Esegue MIB walk completo dopo aver trovato community

`--oid`	—	OID specifico da leggere (es: 1.3.6.1.2.1.1.1.0)
`--write-test`	—	Testa se community "private" ha accesso in scrittura

```
# Community brute force con 70 stringhe integrate
exa-dune snmp --target 192.168.1.50

# Testa community specifica + MIB walk
exa-dune snmp --target 192.168.1.50 --community public --walk

# Leggi OID specifico (sysDescr = info sistema)
exa-dune snmp --target 192.168.1.50 --community public \
         --oid 1.3.6.1.2.1.1.1.0

# Output tipico MIB walk
[+] Community "public" VALIDA
[+] sysDescr: AudioCodes Mediant 2000 VoIP Gateway
[+] sysContact: admin@lab.local
[+] Interfacce: eth0 (192.168.1.50), lo
[+] Route table: 192.168.1.0/24 → eth0
```

OID Utili per IoT/VoIP

OID	NOME	CONTENUTO
`1.3.6.1.2.1.1.1.0`	sysDescr	Descrizione sistema e versione firmware
`1.3.6.1.2.1.1.5.0`	sysName	Hostname del dispositivo
`1.3.6.1.2.1.1.6.0`	sysLocation	Posizione fisica dichiarata
`1.3.6.1.2.1.2.2`	ifTable	Tabella interfacce di rete
`1.3.6.1.2.1.4.20`	ipAddrTable	Indirizzi IP configurati
`1.3.6.1.4.1.9`		MIB proprietaria Cisco

	Cisco enterprise	

mqtt

Subscribe/publish MQTT — protocollo IoT per messaggistica

Cos'è MQTT?

MQTT (Message Queuing Telemetry Transport) è un protocollo leggero publish/subscribe usato massivamente in ambienti IoT (sensori, automazione industriale, smart home). Porta default: **1883/TCP** (non cifrato) o **8883/TCP** (TLS). Un broker MQTT non autenticato permette di intercettare tutti i messaggi dell'impianto.

```
# Discovery e subscribe a tutti i topic
exa-dune mqtt --target 192.168.1.50

# Subscribe a topic specifico
exa-dune mqtt --target 192.168.1.50 --topic "#"

# Publish messaggio su topic
exa-dune mqtt --target 192.168.1.50 --publish --topic "/test" --message "hel

# Con autenticazione
exa-dune mqtt --target 192.168.1.50 --user admin --pass admin
```

modbus

Lettura registri Modbus/TCP — protocollo PLC industriale

Modbus/TCP (porta **502/TCP**) è il protocollo usato in ambienti industriali per controllare PLC (Programmable Logic Controllers), sensori e attuatori. Non ha autenticazione. La lettura dei registri rivela lo stato dell'impianto; la scrittura può modificarlo.

```
# Leggi registri Modbus (holding registers)
exa-dune modbus --target 192.168.1.50
```

```
# Leggi unit ID specifico e range registri
exa-dune modbus --target 192.168.1.50 --unit-id 1 --register 0-100
```

ATTENZIONE — SISTEMI INDUSTRIALI

Scrivere su registri Modbus in un impianto reale può causare malfunzionamenti fisici. Eseguire SOLO in ambienti di laboratorio con dispositivi non critici.

redis

Accesso a Redis non autenticato — database in-memory

Redis (porta **6379/TCP**) è un database chiave-valore in memoria. Spesso deployato senza autenticazione in reti interne. Un Redis esposto permette la lettura di tutti i dati e può essere usato per escalation (es: scrittura chiavi SSH per accesso root).

```
# Test accesso non autenticato + dump keys
exa-dune redis --target 192.168.1.50

# Tenta escalation via authorized_keys
exa-dune redis --target 192.168.1.50 --exploit
```

ldap

Enumerazione directory LDAP/Active Directory

LDAP (porta **389/TCP**, o 636 per LDAPS) è il protocollo per directory aziendali (Active Directory, OpenLDAP). Permette di enumerare utenti, gruppi, configurazioni di rete.

```
# Enumerazione LDAP con null bind (anonimo)
exa-dune ldap --target 192.168.1.50
```

```
# Con credenziali
exa-dune ldap --target 192.168.1.50 --user "cn=admin,dc=lab,dc=local" --pass
```

upnp

Discovery UPnP — Universal Plug and Play

UPnP (porta **1900/UDP**) permette ai dispositivi di scoprirsi e configurarsi automaticamente sulla rete. Spesso espone informazioni dettagliate sul dispositivo e può permettere l'apertura di porte sul router.

```
# Discovery UPnP sulla rete
exa-dune upnp --target 192.168.1.0/24

# Descrizione XML del dispositivo specifico
exa-dune upnp --target 192.168.1.1 --describe
```

tftp

Download file via TFTP — protocollo di trasferimento senza autenticazione

TFTP (Trivial FTP, porta **69/UDP**) è usato da molti dispositivi embedded per il boot di rete (PXE) e aggiornamenti firmware. Non ha autenticazione e permette il download di file di configurazione sensibili se mal configurato.

```
# Tenta download di file di configurazione comuni
exa-dune tftp --target 192.168.1.50

# Download file specifico
exa-dune tftp --target 192.168.1.50 --file startup-config
```

coap

CoAP — Constrained Application Protocol per IoT

CoAP (porta **5683/UDP**) è il protocollo HTTP-like per dispositivi IoT a bassa potenza. Permette GET/PUT/POST su risorse del dispositivo. Raro ma presente su sensori industriali moderni.

```
# Discovery risorse CoAP
exa-dune coap --target 192.168.1.50
```

ipmi IPMI/BMC — gestione server out-of-band

IPMI (porta **623/UDP**) è usato per la gestione remota di server (BMC/iDRAC/iLO). La vulnerabilità IPMI Cipher 0 permette l'autenticazione con qualsiasi password. Molti BMC hanno credenziali di default `admin:admin` o `ADMIN:ADMIN`.

```
# Dump hash password IPMI (Cipher 0 bypass)
exa-dune ipmi --target 192.168.1.50

# Brute force IPMI
exa-dune ipmi --target 192.168.1.50 --brute
```

10. Subcomandi Avanzati

js Analisi JavaScript — estrazione segreti, API keys, endpoint

Analizza i file JavaScript esposti dall'applicazione web per trovare: API key hardcoded, token di autenticazione, endpoint interni non documentati, credenziali, URL di backend. È comune trovare queste informazioni nei file JS di pannelli di amministrazione IoT.

```
# Analisi JS da URL web
exa-dune js --target 192.168.1.50 --port 80

# Output tipico
[+] Trovato: apiKey = "a7b3c9d..."
[+] Trovato: endpoint "/api/v1/admin/reset"
[+] Trovato: password = "admin123" (in commento)
```

fw Firmware Analysis — estrazione e analisi binari dispositivi IoT

Cos'è l'analisi firmware?

Il **firmware** è il software permanente installato su un dispositivo IoT (router, telecamera, gateway VoIP). Analizzarlo permette di trovare: credenziali hardcoded, chiavi crittografiche, backdoor, vulnerabilità nel codice.

Flag Specifici

FLAG	DESCRIZIONE
`--file`	File firmware locale da analizzare

`--url`	URL da cui scaricare il firmware
`--extract`	Estrai il filesystem con binwalk
`--strings`	Cerca stringhe interessanti (password, URL, chiavi)
`--creds`	Cerca credenziali hardcoded nel filesystem estratto

```
# Analisi firmware scaricato manualmente
exa-dune fw --file /root/pentest/firmware.bin --extract --creds

# Download + analisi automatica
exa-dune fw --target 192.168.1.50 --url http://192.168.1.50/firmware.bin --ex

# Output tipico
[+] Tipo: SquashFS filesystem (Linux embedded)
[+] Estrazione in: /tmp/fw_extract/
[+] TROVATO /etc/passwd: root:x:0:0:root
[+] TROVATO /etc/shadow: root:$1$xyz...
[+] TROVATO hardcoded: TELNET_PASS="admin123"
```

Scenario: Analisi Firmware AudioCodes `MP202/MP205`

```
# 1. Scarica firmware dal pannello web
wget http://192.168.1.50/cgi-bin/firmwareupgrade.cgi -O fw.bin

# 2. Analizza con exa-dune
exa-dune fw --file fw.bin --extract --strings --creds

# 3. Cerca file di configurazione SIP nel filesystem estratto
find /tmp/fw_extract -name "*.cfg" -o -name "*.ini" 2>/dev/null
```

`post` Post-Exploitation — raccolta informazioni dopo accesso ottenuto

Cos'è il Post-Exploitation?

Una volta ottenute le credenziali valide, il post-exploitation consiste nel raccogliere tutte le informazioni utili dal sistema compromesso: configurazione, file sensibili, altri dispositivi raggiungibili, informazioni di rete, log di sistema.

Flag Specifici

FLAG	DESCRIZIONE
`--protocol`	Protocollo di accesso: ssh, telnet, ftp, http
`--user`	Username per l'accesso
`--pass`	Password per l'accesso
`--collect-all`	Raccoglie tutto: config, log, utenti, routing
`--dump-config`	Scarica file di configurazione (SSH/FTP/HTTP)
`--enum-network`	Enumera rete raggiungibile dal dispositivo
`--pivot`	Imposta pivot per raggiungere reti interne

```
# Post-exploitation via SSH con credenziali trovate
exa-dune post --target 192.168.1.50 \
         --protocol ssh \
         --user root \
         --pass admin \
         --collect-all

# Solo dump configurazione
exa-dune post --target 192.168.1.50 \
         --protocol http \
         --user Admin \
         --pass Admin \
         --dump-config
```

La `pipeline` automatizzata esegue `post` automaticamente per ogni credenziale trovata.

auto

Automazione multi-target — esegui comandi su file di target

Permette di eseguire lo stesso subcomando su una lista di target da file.

```
# Crea file con lista target
cat > /tmp/targets.txt << 'EOF'
192.168.1.50
192.168.1.51
192.168.1.100
EOF

# Esegui ssh brute force su tutti i target
exa-dune auto --target-file /tmp/targets.txt --command ssh

# Esegui scan sull'intera subnet
exa-dune auto --target-file /tmp/targets.txt --command scan --output-dir /roo
```

report

Generazione report HTML e PDF professionale

Cos'è il Report di Pentest?

Il report è il documento finale che descrive le vulnerabilità trovate, la loro gravità (secondo il sistema CVSS 3.1) e le raccomandazioni per correggerle. exa-dune genera report in formato HTML e PDF pronti per la consegna al cliente.

Flag Specifici

FLAG	DEFAULT	DESCRIZIONE
`--output-dir`	./	Directory contenente gli output degli scan
`--title`		Titolo del report

	Pentest Report	
`--author`	exa-dune	Nome del tester nel report
`--pdf`	—	Genera anche PDF (richiede weasyprint)
`--dry-run`	—	Simula senza scrivere file
`--template`	dark	Template: dark, light, minimal

```
# Genera report HTML dalla directory di scan
exa-dune report --output-dir /root/pentest/scans \
         --title "Pentest Lab AudioCodes" \
         --author "Security Team"

# Genera direttamente in PDF
exa-dune report --output-dir /root/pentest/scans --pdf

# Output
[+] Report HTML: /root/pentest/scans/REPORT_20260321_143500.html
[+] Report PDF:  /root/pentest/scans/REPORT_20260321_143500.pdf
```

Struttura del Report Generato

- **Executive Summary** — Panoramica per il management, senza dettagli tecnici
- **Vulnerability Table** — Tabella con CVSS score, porta, servizio, descrizione
- **Evidence** — Output raw dei tool (nmap, hydra, nikto)
- **Recommendations** — Azioni correttive per ogni vulnerabilità
- **Appendice** — Scope, metodologia, tool usati

CVSS 3.1 — SCALA DI GRAVITÀ

SCORE	GRAVITÀ	COLORE	SIGNIFICATO
9.0–10.0	Critico	CRITICO	Accesso immediato senza autenticazione

7.0–8.9	Alto	ALTO	Credenziali di default, RCE con auth
4.0–6.9	Medio	MEDIO	Informazioni esposte, configurazione debole
0.1–3.9	Basso	BASSO	Rischio limitato, best practice mancanti

10.6 onvif — Telecamere IP ONVIF

Il subcomando `onvif` esegue discovery e brute force su telecamere IP che implementano lo standard **ONVIF** (Open Network Video Interface Forum). Usa SOAP via curl per le chiamate WS-Security.

```
exa-dune onvif --target <IP> [--port 8000] [--output-dir <dir>]
```

FLAG	DEFAULT	DESCRIZIONE
--target / -t	—	IP o hostname della telecamera
--port	8000	Porta ONVIF (comune: 8000, 8080, 80)
--output-dir / -o	./ onvif_<target>	Directory di output

Come funziona

Il modulo ONVIF esegue tre fasi principali:

1. **GetSystemDateAndTime** — proba il servizio ONVIF e verifica l'esistenza dell'endpoint
2. **GetDeviceInformation** — recupera marca, modello, firmware senza autenticazione
3. **WS-Security Brute Force** — prova combinazioni user:pass con PasswordDigest (SHA1 + nonce)

> **PORTE TIPICHE ONVIF**
>
> Le porte più comuni per il servizio ONVIF sono: `8000` (gSOAP), `8080`, `80`. Su Reolink il servizio gSOAP è visibile sulla porta 8000 (`open soap gSOAP 2.8`).

```
# Esempio: brute force ONVIF su telecamera Reolink
exa-dune onvif --target 192.168.1.34 --port 8000 --output-dir /tmp/onvif_test
```

10.7 install — Installazione Automatica dei Tool

Il subcomando `install` installa automaticamente tutti i tool richiesti da exa-dune che non sono presenti sul sistema. Va eseguito **una sola volta come root** al momento della prima installazione.

```
sudo exa-dune install
```

Tool installati

Il comando installa via `apt-get` e `pip3` i seguenti pacchetti:

CATEGORIA	TOOL
Scansione	nmap, masscan, arp-scan, testssl
Web/HTTP	nikto, gobuster, ffuf, curl, wget
Brute Force	hydra, medusa, ncrack
VoIP/IoT	sipvicious, snmpwalk, snmp-mibs-downloader, onesixtyone
Multimedia	ffmpeg, vlc, rtmpdump
mDNS/ Discovery	avahi-utils
SIP Testing	sipsak
Post-Exploit	binwalk, strings, file, xxd
Vulnerability	nuclei (via pip3)
Report	weasyprint (via pip3)

Dopo l'installazione dei tool, `install` esegue automaticamente:

- Creazione della cartella Desktop per i report: `/home/kali/Desktop/EXA-DUNE-Reports/`
- Download delle wordlist aggiuntive da SecLists GitHub: `/usr/share/exa-dune/wordlists/`

PRIMA INSTALLAZIONE

Dopo aver scaricato exa-dune, esegui sempre `sudo exa-dune install` per avere tutti i tool disponibili e le wordlist aggiornate da SecLists.

```
# Workflow tipico di prima installazione
git clone https://github.com/Sal1699/exa-dune.git
cd exa-dune && chmod +x exa-dune
sudo ./exa-dune install    # installa tutto
exa-dune --version         # verifica installazione
```

10.8 wordlists — Gestione Wordlist

Il subcomando `wordlists` scarica wordlist aggiuntive da SecLists GitHub e le installa in `/usr/share/exa-dune/wordlists/`. Richiede connessione internet e privilegi root.

```
sudo exa-dune wordlists
```

Wordlist scaricate da SecLists

FILE	VOCI	SCOPO
top-usernames-shortlist.txt	15	Utenti più comuni
probable-v2-top1575.txt	1575	Password probabili
common.txt (DNS)	4989	Sottodomini comuni
common.txt (web)	4724	Path web comuni
CGIs.txt	3462	CGI endpoint
snmp-onesixtyone.txt	100	Community SNMP
ssh-betterdefault.txt	30	Default SSH
ftp-betterdefault.txt	30	Default FTP
sip-extensions.txt	2000	Extension SIP
rtsp-urls.txt	100	Path RTSP
iot-default.txt	65	Credenziali IoT predefinite
... + 13 altri	—	LFI, telnet, rdp, smb, ecc.

PRIORITÀ WORDLIST

> Se una wordlist esiste in `/usr/share/exa-dune/wordlists/`, viene usata al posto di quella integrata nel codice. Le wordlist embedded sono sempre disponibili come fallback anche offline.

10.9 Nuovi Subcomandi IoT/OT — v2.5.0

La versione 2.5.0 introduce **7 nuovi subcomandi** specializzati per protocolli IoT/OT non coperti in precedenza: mDNS, WS-Discovery, BACnet/IP, RTMP, Camera CVE, SIP Fuzzing, EtherNet/IP.

mdns — mDNS/Bonjour Service Discovery

Enumera servizi mDNS sulla rete locale tramite `avahi-browse` e NSE `dns-service-discovery`. Identifica dispositivi IoT, telecamere, stampanti, HomeKit, Chromecast.

```
exa-dune mdns                      # scan rete locale
exa-dune mdns 192.168.1.0/24       # con target specifico
exa-dune mdns --iface eth0 --timeout 30
```

OPZIONE	DEFAULT	DESCRIZIONE
--iface	—	Interfaccia di rete da usare (es: eth0, wlan0)
--timeout	10	Timeout ascolto multicast in secondi
--output	auto	Directory output

TOOL RICHIESTI

`avahi-utils` (apt) — installato via `exa-dune install`

wsd — WS-Discovery / SSDP

Rileva dispositivi WS-Discovery (ONVIF, stampanti, NAS, smart TV) via UDP multicast 3702. Esegue anche SSDP M-SEARCH su porta 1900 per dispositivi UPnP.

```
exa-dune wsd 192.168.1.50         # probe WSD + SSDP
exa-dune wsd 192.168.1.50 --port 3702 --timeout 10
```

OPZIONE	DEFAULT	DESCRIZIONE
--port	3702	Porta WSD UDP
--timeout	5	Timeout ascolto risposta in secondi

bacnet — BACnet/IP (Building Automation)

Enumera dispositivi BACnet/IP (HVAC, PLC, sensori) tramite NSE `bacnet-info` e Who-Is broadcast su UDP 47808. Copre automazione edifici e sistemi ICS.

```
exa-dune bacnet 192.168.1.100     # scan BACnet
exa-dune bacnet 192.168.1.0/24 --port 47808
```

OPZIONE	DEFAULT	DESCRIZIONE
--port	47808	Porta BACnet/IP UDP

> **ATTENZIONE OT**
> Non eseguire test BACnet su sistemi in produzione senza autorizzazione esplicita. I dispositivi BACnet sono spesso PLC critici per HVAC e safety.

rtmp — RTMP Stream Enumeration

Proba server RTMP (DVR, NVR, telecamere IP) su porta 1935. Enumera 20 path comuni (live, stream, cam, dvr, ch1…), verifica accesso anonimo con ffprobe, cattura metadati stream.

```
exa-dune rtmp 192.168.1.34        # probe RTMP porta 1935
exa-dune rtmp 192.168.1.34 --port 1935 --apps /custom/wordlist.txt
```

OPZIONE	DEFAULT	DESCRIZIONE

--port	1935	Porta RTMP TCP
--apps	embedded	File con lista di app/stream da provare (1 per riga)

TOOL RICHIESTI

`ffmpeg` (ffprobe) + `rtmpdump` — installati via `exa-dune install`

cam-cve — IP Camera CVE Scanner

Verifica vulnerabilità note su telecamere IP con detection automatica vendor (Hikvision, Dahua, Axis, Reolink, generic). Controlla endpoint CVE noti e disclosure unauthenticated.

```
exa-dune cam-cve 192.168.1.34                    # auto-detect vendor
exa-dune cam-cve 192.168.1.34 --vendor hikvision
exa-dune cam-cve 192.168.1.34 --vendor axis --ssl
```

OPZIONE	DEFAULT	DESCRIZIONE
--vendor	auto	hikvision | dahua | axis | reolink | generic
--port	80	Porta HTTP
--ssl	off	Usa HTTPS su porta 443

CVE SUPPORTATI	VENDOR	SEVERITY
CVE-2021-36260 — Unauthenticated RCE via webLanguage	Hikvision	CRITICAL
CVE-2017-7921 — Unauthenticated snapshot bypass	Hikvision	HIGH
CVE-2021-33044 — Auth bypass via magic packet	Dahua	CRITICAL
CVE-2017-7925 — Unauthenticated config dump	Dahua	CRITICAL
	Axis	CRITICAL

CVE-2018-10660 — Root shell via VAPIX param injection		
CVE-2016-6201 — Snapshot auth bypass	Axis	HIGH
INFO-DISC-* — Device info/API senza autenticazione	Reolink	MEDIUM

sip-fuzz — SIP Fuzzing e Stress Test

Invia messaggi SIP malformati, effettua tracerouting SIP e stress test INVITE tramite `sipsak`. Complementa sipvicious (enumeration) con test di robustezza del server.

```
exa-dune sip-fuzz 192.168.1.10            # OPTIONS probe + trace
exa-dune sip-fuzz 192.168.1.10 --method INVITE --count 100
exa-dune sip-fuzz 192.168.1.10 --port 5060 --sleep 50
```

OPZIONE	DEFAULT	DESCRIZIONE
--port	5060	Porta SIP UDP/TCP
--method	OPTIONS	Metodo SIP: OPTIONS | INVITE | REGISTER
--count	50	Numero messaggi per stress test
--sleep	100	Delay tra messaggi in millisecondi

TOOL RICHIESTI

`sipsak` — installato via `exa-dune install`

enip — EtherNet/IP (ICS/SCADA)

Enumera controller PLC EtherNet/IP (Allen-Bradley, Rockwell) tramite NSE `enip-info` e CIP ListIdentity broadcast su TCP/UDP 44818. Identifica vendor, product name, revisione firmware.

```
exa-dune enip 192.168.1.100       # scan EtherNet/IP
exa-dune enip 192.168.1.0/24 --port 44818
```

OPZIONE	DEFAULT	DESCRIZIONE
--port	44818	Porta EtherNet/IP TCP/UDP

ATTENZIONE ICS

EtherNet/IP è usato su PLC in ambienti industriali critici. Non eseguire mai senza autorizzazione esplicita e in orari concordati con i responsabili OT.

Riepilogo — Nuovi Subcomandi v2.5.0

SUBCOMANDO	PROTOCOLLO/ PORTA	VENDOR/ SCOPE	TOOL
`mdns`	UDP 5353	IoT/LAN universale	avahi-browse, nmap NSE
`wsd`	UDP 3702, UDP 1900	ONVIF, UPnP	Python3, nmap NSE
`bacnet`	UDP 47808	Building Automation (HVAC, PLC)	nmap NSE, Python3
`rtmp`	TCP 1935	DVR, NVR, streaming	ffprobe, rtmpdump
`cam-cve`	TCP 80/443	Hikvision, Dahua, Axis, Reolink	curl (built-in)
`sip-fuzz`	UDP/TCP 5060	SIP server, PBX	sipsak, nmap NSE
`enip`	TCP/UDP 44818		nmap NSE, Python3

		PLC Allen-Bradley/ Rockwell	

11. Pipeline Automatizzata

FUNZIONALITÀ V2.5.0

La pipeline automatizzata è la funzionalità più potente di exa-dune: esegue l'intero ciclo di penetration testing in un singolo comando, dalla scansione iniziale al report PDF finale.

11.1 Le 5 Fasi della Pipeline

FASE 1

Scansione

Esegue `nmap` sul target con rilevamento versioni e script NSE. Salva i risultati in formato .nmap, .xml e .gnmap per l'analisi automatica. Con `--from-scan DIR` questa fase viene saltata e si usano scan precedenti.

FASE 2

Analisi e Suggerimenti

Legge l'output nmap e mappa le porte aperte ai moduli di attacco appropriati. Ogni suggerimento ha una priorità da 1 (critico) a 25 (basso). La lista viene mostrata ordinata per priorità con codice colore: rosso=critico, giallo=medio, verde=basso.

FASE 3

Esecuzione Attacchi

Esegue ogni attacco suggerito in ordine di priorità. Per ogni attacco registra l'output completo. Se non vengono trovate vulnerabilità, logga "nessuna vulnerabilità rilevata". Con `--auto` non chiede conferma prima di ogni attacco.

FASE 4

Post-Exploitation Automatico

Se hydra ha trovato credenziali valide, le legge automaticamente e lancia `exa-dune post` per raccogliere informazioni dal sistema compromesso. Con `--no-post` questa fase viene saltata.

FASE 5

Generazione Report PDF

Aggrega tutti gli output delle fasi precedenti in un report HTML strutturato e lo converte in PDF con weasyprint. Il report include executive summary, tabella vulnerabilità, evidenze e raccomandazioni.

11.2 Sintassi Completa

```
exa-dune pipeline --target TARGET [opzioni]
```

11.3 Flag Specifici Pipeline

FLAG	DEFAULT	DESCRIZIONE
`--target / -t`	—	Target: IP singolo, CIDR, o hostname
`--output-dir / -o`	./pipeline_TIMESTAMP	Directory output per tutti i file
`--auto`	—	Esegui senza chiedere conferma ad ogni fase
`--from-scan DIR`	—	Usa scan nmap esistente, salta Fase 1
`--no-post`	—	Salta Fase 4 (post-exploitation)
`--stealth`	—	Modalità silenziosa in tutte le fasi

`--timeout N`	300	Timeout in secondi per ogni singolo attacco
`--dry-run`	—	Simula tutto senza eseguire azioni reali
`--pdf`	—	Genera PDF (attivo di default se weasyprint disponibile)

11.4 Esempi Pratici

```
── UTILIZZO BASE ──
# Pipeline completa su target singolo
exa-dune pipeline --target 192.168.1.50 --output-dir /root/pentest/scans

── MODALITÀ AUTOMATICA ──
# Nessuna interazione richiesta, ideale per script
exa-dune pipeline --target 192.168.1.50 --auto --output-dir /root/pentest/scans

── RIUSO SCAN ESISTENTE ──
# Salta la scansione, usa risultati precedenti
exa-dune pipeline --from-scan /root/pentest/scans/scan_20260321/ \
         --auto --output-dir /root/pentest/scans

── SILENZIOSA SENZA POST-EXPLOIT ──
exa-dune pipeline --target 192.168.1.50 \
         --stealth --no-post \
         --timeout 600 \
         --output-dir /root/pentest/scans

── DRY RUN (test senza azioni) ──
exa-dune pipeline --target 192.168.1.50 --dry-run
```

11.5 Output della Pipeline

```
╔═══════════════════════════════════════════════════════╗
║         exa-dune PIPELINE — 192.168.1.50              ║
╚═══════════════════════════════════════════════════════╝
```

```
[FASE 1/5] Scansione...
[+] nmap completato. Porte: 22, 80, 443, 5060, 8080

[FASE 2/5] Analisi risultati...
[P01] sip   --target 192.168.1.50 --port 5060  → SIP esposto
[P05] ssh   --target 192.168.1.50              → SSH bruteforce
[P08] web   --target 192.168.1.50 --port 80    → HTTP audit
[P09] web   --target 192.168.1.50 --port 8080  → HTTP-alt audit
[P12] ssl   --target 192.168.1.50 --port 443   → TLS audit

[FASE 3/5] Esecuzione 5 attacchi...
[1/5] sip...
      [+] Extension 100 trovata, PIN crackato: 1234
[2/5] ssh...
      [+] FOUND: root:admin
[3/5] web (porta 80)...
      [+] /admin/: 200 OK
      [+] /cgi-bin/status.cgi: 200 OK
[4/5] web (porta 8080)...
      [-] nessuna vulnerabilità rilevata
[5/5] ssl...
      [+] TLS 1.0 abilitato, cert autofirmato

[FASE 4/5] Post-exploitation (2 credenziali trovate)...
      [+] SSH root:admin → raccolta config completata

[FASE 5/5] Generazione report...
[+] Report HTML: /root/pentest/scans/REPORT_20260321_145030.html
[+] Report PDF:  /root/pentest/scans/REPORT_20260321_145030.pdf
✓ Pipeline completata in 4m 32s
```

11.6 Mappatura Porte → Moduli

PORTA	SERVIZIO	MODULO	PRIORITÀ
5060	SIP/VoIP	sip	P1 CRITICO
5061	SIP-TLS	sip --tls	P2 CRITICO
23	Telnet	telnet	P3 CRITICO
161	SNMP	snmp	P4 CRITICO

22	SSH	ssh	P5
21	FTP	ftp	P6
554	RTSP	rtsp	P7
80	HTTP	web, http	P8
443	HTTPS	web, ssl	P9
445	SMB	smb	P10
1883	MQTT	mqtt	P11
502	Modbus	modbus	P12
6379	Redis	redis	P13
3389	RDP	rdp	P14
5900	VNC	vnc	P15
389	LDAP	ldap	P16
1900	UPnP	upnp	P17
69	TFTP	tftp	P18
623	IPMI	ipmi	P19
53	DNS	dns	P20

12. Scenari Pratici di Laboratorio

Questa sezione descrive procedure step-by-step per i dispositivi specifici del laboratorio.

12.1 AudioCodes MP202/MP205

DISPOSITIVO

Gateway VoIP analogico che converte porte FXS (telefoni analogici) in SIP. Tipicamente espone pannello web (HTTP/HTTPS), SIP (5060), e talvolta SSH o Telnet.

Procedura Completa: AudioCodes MP202 `192.168.1.50`

```
== STEP 1: Discovery iniziale ==
exa-dune scan --target 192.168.1.50 --output-dir /root/pentest/scans
# Tipicamente trovi: 80/tcp (HTTP), 443/tcp (HTTPS), 5060/udp (SIP)

== STEP 2: Audit pannello web ==
exa-dune web --target 192.168.1.50 --port 80
exa-dune http --target 192.168.1.50 --port 80
# Cerca: /cgi-bin/status.cgi, /admin/, /config.html

== STEP 3: Credenziali default pannello ==
exa-dune creds --target 192.168.1.50 --port 80 --protocol http
# AudioCodes default: Admin/Admin (A maiuscola!)

== STEP 4: Enumerazione SIP ==
exa-dune sip --target 192.168.1.50 --enum --extension-range 1-10
# MP202 = 2 porte FXS → max 2 estensioni
# MP205 = 5 porte FXS → max 5 estensioni

== STEP 5: Crack PIN SIP ==
exa-dune sip --target 192.168.1.50 --crack
```

```
== STEP 6: SNMP (se attivo) ==
exa-dune snmp --target 192.168.1.50 --walk
# AudioCodes community default: "public"

== OPZIONALE: Pipeline automatica ==
exa-dune pipeline --target 192.168.1.50 --auto --output-dir /root/pentest/sca
```

Vulnerabilità Tipiche AudioCodes

VULNERABILITÀ	CVSS	GRAVITÀ	DESCRIZIONE
Credenziali default Admin:Admin	9.8	CRITICO	Accesso completo al pannello senza modifica password
SIP PIN deboli (1234, 0000)	8.1	ALTO	Permette effettuare chiamate a spese dell'intestatario
SNMP community "public" R/W	7.5	ALTO	Lettura e modifica configurazione completa via SNMP
TLS 1.0 abilitato	5.3	MEDIO	Protocollo deprecato, vulnerabile a POODLE
Certificato autofirmato	4.3	MEDIO	Man-in-the-middle possibile senza warning utente

12.2 Commend SIP Station ET962-BF5xx

DISPOSITIVO

Stazione citofonico/intercom SIP di alta qualità. Espone interfaccia web e SIP. Usato in applicazioni di sicurezza fisica: portiere, accesso edifici.

Procedura: Commend ET962 `192.168.1.x`

```
# Scan iniziale
exa-dune scan --target 192.168.1.60 --scan-type A --output-dir /root/pentest/

# Il Commend espone tipicamente: 80 (HTTP config), 5060 (SIP), 554 (RTSP audi

# Test pannello web
exa-dune web --target 192.168.1.60 --port 80 --nikto

# Credenziali web (Commend default varia per modello)
exa-dune creds --target 192.168.1.60 --protocol http

# SIP: cerca account configurati
exa-dune sip --target 192.168.1.60 --enum

# RTSP audio stream (se porta 554 aperta)
exa-dune rtsp --target 192.168.1.60 --brute-path
```

12.3 GAI-Tronics Commander VoIP

DISPOSITIVO

Telefono industriale VoIP robusto (ambienti pericolosi, industria). Pannello web di configurazione, SIP, e in alcuni modelli telnet per manutenzione.

Procedura: GAI-Tronics Commander `192.168.1.x`

```
# Pipeline automatica completa
exa-dune pipeline --target 192.168.1.70 --auto \
          --output-dir /root/pentest/scans

# Oppure manuale:
exa-dune scan --target 192.168.1.70 --output-dir /root/pentest/scans
exa-dune web --target 192.168.1.70
```

```
exa-dune telnet --target 192.168.1.70  # Se porta 23 aperta
exa-dune sip --target 192.168.1.70 --enum
```

12.4 Axis IP Camera

DISPOSITIVO

Telecamera IP professionale. Espone HTTP/HTTPS per configurazione, RTSP per streaming, e in alcuni modelli SSH. API proprietaria `/axis-cgi/`.

Procedura: Axis Camera `192.168.1.100`

```
== Scan con script NSE per Axis ==
exa-dune scan --target 192.168.1.100 --script http-auth-finder \
         --output-dir /root/pentest/scans

== Audit web API Axis ==
exa-dune web --target 192.168.1.100 --port 80
# Cerca: /axis-cgi/admin/, /axis-cgi/param.cgi
# URL stream: http://192.168.1.100/axis-cgi/mjpg/video.cgi

== Credenziali default Axis ==
# Axis modelli vecchi: root/(vuota) o root/pass
# Axis modelli nuovi: admin/(da configurare al primo boot)
exa-dune creds --target 192.168.1.100 --protocol http

== Stream RTSP ==
exa-dune rtsp --target 192.168.1.100 --brute-path
# Path comuni Axis: /axis-media/media.amp
#                   /mpeg4/media.amp

== SSL (Axis usa HTTPS self-signed) ==
exa-dune ssl --target 192.168.1.100 --port 443

== Firmware (scarica dal pannello) ==
# Prima ottieni accesso al pannello admin, poi:
exa-dune fw --target 192.168.1.100 \
```

```
          --url http://admin:@192.168.1.100/axis-cgi/firmware.cgi \
          --extract
```

12.5 Scenario: Scoperta Rete Completa

Procedura: Scoperta e Pentest Intera Subnet

```
═══════════════════════════════════════════════
  STEP 1: Ping sweep — trova tutti gli host
═══════════════════════════════════════════════
exa-dune scan --target 192.168.1.0/24 \
         --ping-sweep \
         --output-dir /root/pentest/scans/discovery

═══════════════════════════════════════════════
  STEP 2: Scan veloce porte principali
═══════════════════════════════════════════════
exa-dune scan --target 192.168.1.0/24 \
         --top-ports 100 \
         --output-dir /root/pentest/scans/quick

═══════════════════════════════════════════════
  STEP 3: Scan dettagliato host rilevati
═══════════════════════════════════════════════
# Per ogni host trovato al passo 2:
for ip in 192.168.1.50 192.168.1.60 192.168.1.100; do
  exa-dune scan --target $ip --scan-type A \
           --output-dir /root/pentest/scans/deep_$ip
done

═══════════════════════════════════════════════
  STEP 4: Pipeline su ogni host
═══════════════════════════════════════════════
for ip in 192.168.1.50 192.168.1.60 192.168.1.100; do
  exa-dune pipeline \
           --from-scan /root/pentest/scans/deep_$ip \
           --auto \
           --output-dir /root/pentest/results_$ip
done
```

```
═══════════════════════════════════════════════
  STEP 5: Report consolidato
═══════════════════════════════════════════════
exa-dune report --output-dir /root/pentest/ \
         --title "Pentest Laboratorio IoT/VoIP 2026" \
         --pdf
```

13. Glossario per Principianti

Definizioni dei termini tecnici usati in questo manuale, con spiegazioni accessibili.

Banner Grabbing

Tecnica per leggere il "banner" (messaggio di benvenuto) di un servizio che rivela la versione del software. Es: `SSH-2.0-OpenSSH_7.4`. Utile per trovare versioni vulnerabili.

Brute Force

Attacco che prova sistematicamente molte combinazioni di credenziali (username/password) fino a trovare quella corretta. Contrapposto al "dictionary attack" che usa una lista di parole predefinite.

CGI (Common Gateway Interface)

Standard per eseguire programmi sul server web. Le URL che contengono `/cgi-bin/` spesso eseguono script che possono avere vulnerabilità di injection.

CIDR (Classless Inter-Domain Routing)

Notazione per specificare range di indirizzi IP. `192.168.1.0/24` indica tutti gli indirizzi da 192.168.1.0 a 192.168.1.255 (256 host). `/24` indica 24 bit di network.

Community String (SNMP)

La "password" del protocollo SNMP. Le più comuni sono `public` (sola lettura) e `private` (lettura/scrittura). Molti dispositivi le lasciano al valore di default.

CVE (Common Vulnerabilities and Exposures)

Sistema di identificazione standard per vulnerabilità note. Formato: `CVE-ANNO-NUMERO` (es: CVE-2021-44228 = Log4Shell). Ogni CVE è una vulnerabilità documentata pubblicamente.

CVSS (Common Vulnerability Scoring System)

Sistema di valutazione della gravità delle vulnerabilità da 0.0 a 10.0. Versione 3.1 è quella attuale. Considera vettore d'attacco, complessità, privilegi richiesti, impatto. Score ≥9.0 = critico.

Default Credentials

Username e password preimpostate in fabbrica (es: admin/admin). Sono la prima cosa da cambiare su qualsiasi dispositivo. La maggior parte delle compromissioni IoT sfruttano credenziali di default non cambiate.

Directory Traversal / Path Traversal

Vulnerabilità che permette di accedere a file fuori dalla directory web usando `../`. Esempio: `http://victim/page?file=../../../etc/passwd`. Anche chiamata LFI (Local File Inclusion).

Dry Run

Modalità di esecuzione che mostra i comandi che verrebbero eseguiti senza eseguirli realmente. Utile per verificare cosa farebbe lo strumento prima di procedere.

Enumeration

Fase di ricognizione che raccoglie informazioni specifiche su un target: utenti, directory, servizi, condivisioni. Più dettagliata del semplice scan di porte.

Exploit

Codice o tecnica che sfrutta una vulnerabilità per ottenere un accesso non autorizzato o eseguire azioni non previste. Un exploit "in the wild" è già usato da attaccanti reali.

Extension (SIP)

Identificatore numerico (solitamente 3-4 cifre) di un account SIP. Equivale al "numero interno" di un centralino. Es: estensione 200 = telefono IP 192.168.1.50, account 200.

Firmware

Software permanente installato nella memoria flash di un dispositivo hardware. Controlla il funzionamento del dispositivo. I firmware obsoleti spesso contengono vulnerabilità note.

Fuzzing

Tecnica di testing che invia input casuali o sistematici a un programma per trovare comportamenti inattesi (crash, errori, accessi non autorizzati). Il web fuzzing cerca percorsi URL nascosti.

Gateway VoIP

Dispositivo che converte segnale telefonico analogico (PSTN) in VoIP digitale. Es: AudioCodes MP202 converte telefoni analogici in chiamate SIP su Internet.

---

hydra

Tool di brute force per reti, open source, incluso in Kali Linux. Supporta oltre 30 protocolli: SSH, FTP, HTTP, SIP, RDP, VNC e molti altri. Usato internamente da exa-dune per brute force.

IoT (Internet of Things)

Dispositivi fisici connessi a Internet: telecamere, sensori, router, gateway VoIP, elettrodomestici "smart". Spesso hanno sicurezza debole per ridurre i costi di produzione.

LFI (Local File Inclusion)

Vulnerabilità web che permette di leggere file locali del server attraverso un parametro URL manipolato. Target comune: `/etc/passwd`, `/etc/shadow`, file di configurazione.

MIB (Management Information Base)

Database gerarchico di informazioni gestibili via SNMP. Ogni nodo ha un OID (Object Identifier) numerico. La MIB di un dispositivo espone tutto: configurazione, statistiche, utenti.

---

nmap

Network Mapper — tool open source per scansione di rete. Uno dei più usati in sicurezza informatica. Rileva host attivi, porte aperte, versioni dei servizi e può eseguire script NSE di sicurezza.

NSE (Nmap Scripting Engine)

Sistema di scripting di nmap che permette di eseguire analisi avanzate. Script come `vuln` testano vulnerabilità note, `auth` testa credenziali di default, `brute` fa brute force.

OID (Object Identifier)

Identificatore numerico gerarchico per oggetti SNMP. Formato: numeri separati da punti (es: 1.3.6.1.2.1.1.1.0 = sysDescr). Leggi un OID per ottenere quella specifica informazione dal dispositivo.

Penetration Testing

Attività professionale autorizzata di test sicurezza che simula un attacco reale per trovare vulnerabilità. Distinto dall'"hacking" non autorizzato per il consenso esplicito del proprietario del sistema.

PIN (SIP)

Codice numerico (tipicamente 4-6 cifre) che autentica un account SIP. I PIN deboli (1234, 0000) permettono a chiunque di registrare quell'estensione e effettuare chiamate.

Pipeline

In exa-dune: sequenza automatizzata di fasi (scan → analisi → attacchi → post-exploit → report). In Unix: concatenazione di comandi con `|` dove l'output di uno diventa input del successivo.

Port Scanning

Processo di sondare un dispositivo su tutte le porte per determinare quali sono aperte e quali servizi le usano. Punto di partenza di ogni penetration test.

Post-Exploitation

Fase dopo aver ottenuto accesso: raccolta di informazioni, mantenimento dell'accesso, escalation privilegi, pivot verso altri sistemi. Dimostra l'impatto reale della vulnerabilità.

RCE (Remote Code Execution)

Vulnerabilità critica che permette di eseguire codice arbitrario su un sistema remoto senza autenticazione. CVSS spesso 9.0-10.0. La vulnerabilità più pericolosa esistente.

SecLists

Raccolta open source di wordlist per sicurezza: password, username, percorsi web, payload. Su Kali: `/usr/share/seclists/`. exa-dune le usa se disponibili, altrimenti usa le wordlist integrate.

SIP (Session Initiation Protocol)

Protocollo standard RFC 3261 per comunicazioni multimediali (VoIP). Gestisce la segnalazione: chi chiama chi, negoziazione codec, avvio/fine chiamata. Porta default: 5060/UDP.

Stealth Scan

Scansione "furtiva" che riduce il numero di pacchetti e la velocità per evitare il rilevamento da IDS/IPS e firewall. In exa-dune: attivato con `--stealth`, usa timing T2 e 1 thread.

TLS/SSL

Protocolli crittografici per comunicazioni sicure su Internet. SSL è obsoleto; TLS 1.2 e 1.3 sono attuali. TLS 1.0/1.1 sono deprecati e vulnerabili. HTTPS usa TLS su HTTP.

VoIP (Voice over IP)

Tecnologia che trasmette voce su reti IP invece delle tradizionali linee telefoniche. Usa protocolli come SIP per la segnalazione e RTP per il trasporto audio.

Wordlist

File di testo con una parola per riga, usato per attacchi dizionario. In exa-dune v2.4.0: 7 wordlist integrate (embedded) + 24 wordlist aggiuntive da SecLists per utenti, password, web, SNMP, LFI, DNS, credenziali IoT, RTSP, SIP.

Zone Transfer (AXFR)

Meccanismo DNS per replicare tutti i record di un dominio da un server a un altro. Se mal configurato, rivela l'intera struttura della rete interna a qualsiasi richiedente.

---

14. Cheat Sheet Rapido

Riferimento rapido per i comandi più usati. Stampare e tenere a portata di mano durante l'engagement.

SCANSIONE INIZIALE

```
# Ping sweep
exa-dune scan -t 192.168.1.0/24 \
  --ping-sweep

# Scan veloce
exa-dune scan -t 192.168.1.0/24 \
  --top-ports 100 -o /tmp/scan

# Scan completo
exa-dune scan -t 192.168.1.50 \
  --scan-type A -o /tmp/scan

# Solo porte VoIP
exa-dune scan -t 192.168.1.0/24 \
  --ports 5060,5061,5080 -o /tmp/scan
```

PIPELINE (TUTTO AUTOMATICO)

```
# Pipeline completa
exa-dune pipeline -t 192.168.1.50 \
  --auto -o /tmp/results

# Da scan esistente
exa-dune pipeline \
  --from-scan /tmp/scan/ \
  --auto -o /tmp/results

# Silenzioso
exa-dune pipeline -t 192.168.1.50 \
  --stealth --no-post -o /tmp/results

# Dry run
exa-dune pipeline -t TARGET --dry-run
```

VOIP / SIP

```
# Discovery SIP
exa-dune sip -t 192.168.1.50

# Enum estensioni
exa-dune sip -t 192.168.1.50 \
  --enum --extension-range 100-999

# Crack PIN
exa-dune sip -t 192.168.1.50 --crack

# RTSP stream
exa-dune rtsp -t 192.168.1.100 \
  --brute-path
```

CREDENZIALI / BRUTE FORCE

```
# Creds default IoT
exa-dune creds -t 192.168.1.50

# SSH brute
exa-dune ssh -t 192.168.1.50

# Telnet brute
exa-dune telnet -t 192.168.1.50

# FTP + anon
exa-dune ftp -t 192.168.1.50

# Con wordlist custom
exa-dune ssh -t 192.168.1.50 \
  --user-list /usr/share/... \
  --pass-list /usr/share/...
```

PROTOCOLLI IOT

```
# SNMP community brute
exa-dune snmp -t 192.168.1.50

# SNMP walk
exa-dune snmp -t 192.168.1.50 \
  --community public --walk

# MQTT subscribe all
exa-dune mqtt -t 192.168.1.50 \
  --topic "#"

# Modbus read
exa-dune modbus -t 192.168.1.50
```

WEB / HTTP

```
# Directory fuzzing
exa-dune web -t 192.168.1.50 -p 80

# HTTPS + nikto + LFI
exa-dune web -t 192.168.1.50 \
  -p 443 --https --nikto --lfi

# Header analysis
exa-dune http -t 192.168.1.50 -p 80

# TLS audit
exa-dune ssl -t 192.168.1.50 -p 443
```

FIRMWARE / POST-EXPLOIT

```
# Analisi firmware
exa-dune fw --file firmware.bin \
  --extract --creds

# Post-exploit SSH
exa-dune post -t 192.168.1.50 \
  --protocol ssh \
  --user root --pass admin \
  --collect-all

# DNS zone transfer
exa-dune dns -t 192.168.1.1 \
  --domain lab.local --axfr
```

REPORT PDF

```
# Report HTML
exa-dune report -o /tmp/scan \
  --title "Lab Pentest"

# Report PDF
exa-dune report -o /tmp/scan \
  --pdf --title "Lab Pentest" \
  --author "Security Team"

# Dry run report
exa-dune report -o /tmp/scan \
  --pdf --dry-run
```

Porte di Riferimento Rapido

21 FTP	22 SSH	23 Telnet	53 DNS	69 TFTP	80 HTTP
161 SNMP	389 LDAP	443 HTTPS	445 SMB	502 Modbus	554 RTSP
623 IPMI	636 LDAPS	1883 MQTT	1900 UPnP	3389 RDP	5060 SIP

`5061` SIP-TLS	`5683` CoAP	`5900` VNC	`6379` Redis	`8080` HTTP-alt	`8883` MQTT-TLS

Credenziali Default più Comuni (IoT/VoIP)

VENDOR / PRODOTTO	USERNAME	PASSWORD
Generico	admin	admin, password, 1234, (vuota)
AudioCodes	Admin	Admin
Ubiquiti AirOS	ubnt	ubnt
Raspberry Pi	pi	raspberry
Cisco IOS	cisco	cisco, (vuota)
Axis Camera	root	(vuota), pass
Huawei router	root / admin	admin, Huawei12#$
Mirai (tanti IoT)	root	vizxv, xc3511, 888888
APC UPS	apc	apc
Teltonika	admin	admin01

15. Changelog e Versioni

v2.5.0 — Marzo 2026

- **7 nuovi subcomandi IoT/OT** — `mdns`, `wsd`, `bacnet`, `rtmp`, `cam-cve`, `sip-fuzz`, `enip`: coprono mDNS/Bonjour, WS-Discovery/SSDP, BACnet/IP, RTMP stream, CVE telecamere IP, SIP fuzzing, EtherNet/IP CIP
- **Pipeline parallela** — flag `--parallel` esegue i moduli in background bash job con `wait` finale; riduce tempo totale audit multi-modulo
- **Timeline per fase** — `_timeline_event()` registra timestamp START/END/SKIP in `timeline.txt`; il report HTML mostra la sezione 8 Timeline con codifica colori
- **Report completo per fase** — Report HTML v2.5.0 aggiunge: UDP ports (2b), SSL/TLS detail (2c), ARP (2d), searchsploit (2e), RTSP streams+snapshot (4b), SIP/VoIP (4c), JS Analysis (4d), SSH/FTP (4e), tabella moduli con findings (7), timeline (8), appendice log (9)
- **Camera CVE scanner** — Auto-detection vendor da HTTP header, check CVE-2021-36260, CVE-2017-7921 (Hikvision), CVE-2021-33044, CVE-2017-7925 (Dahua), CVE-2018-10660, CVE-2016-6201 (Axis)
- **_suggest_attacks() aggiornato** — mapping porta→modulo corretto: RTMP→rtmp, WSD→wsd, BACnet→bacnet, mDNS→mdns, EtherNet/IP→enip, ONVIF→onvif, CoAP→coap

- **Fix `run_cmd` nei 7 nuovi subcomandi** — corretti 12 chiamate con argomenti invertiti (comando/outfile) in `cmd_mdns`, `cmd_wsd`, `cmd_bacnet`, `cmd_rtmp`, `cmd_sipfuzz`, `cmd_enip`
- **Install aggiornato** — `exa-dune install` aggiunge automaticamente: `sipsak`, `rtmpdump`, `avahi-utils`

v2.4.0 — Marzo 2026

- **Report HTML/PDF professionale** — Cover page, executive summary, stat boxes, bar chart severity, porte/servizi da nmap, findings con CVSS 3.1, raccomandazioni, log appendice
- **Desktop Reports dir** — `/home/kali/Desktop/EXA-DUNE-Reports/` creata automaticamente. Ogni PDF viene copiato qui automaticamente dopo la generazione
- **Auto-install weasyprint** — `exa-dune install` installa weasyprint via pip3 per la conversione HTML→PDF
- **Fix `rest: unbound variable`** — Risolto crash nel bar chart del report HTML con `set -u`

v2.3.0 — Marzo 2026

- **Fix `run_cmd()`** — Doppio bash rimosso nel timeout; `|| true` previene exit prematuro con `set -e`
- **Fix `validate_target()`** — Supporto CIDR (`/0-32`) e hostname semplici senza TLD
- **Fix `validate_timeout()`** — Nuova funzione, range 1-1440 minuti
- **Fix `setup_outdir()`** — mkdir con messaggio di errore esplicito

- **Fix** `_wl_rtsp_paths()` — Temp file leak risolto con variabile globale `_FALLBACK_RTSP` e cleanup trap
- **Fix Nuclei flags** — Flag corretti: `-duc -nh -no-verify` (compatibile v3.7.1+)
- **Fix testssl** — Binary corretto su Kali è `testssl` (non `testssl.sh`)

v2.2.0 — Marzo 2026

- **Auto-install media tools** — `_ensure_media_tools()` installa ffmpeg e vlc via apt se assenti
- **RTSP snapshot con ffmpeg/cvlc** — Cattura frame dalle telecamere via RTSP (ffmpeg primario, cvlc fallback con `--allow-user-root`)
- **Subcomando** `install` — Installa tutti i 34 tool mancanti (apt + pip3) con un solo comando
- **Subcomando** `wordlists` — Scarica 24 wordlist da SecLists GitHub in `/usr/share/exa-dune/wordlists/`
- **RTSP path branding** — Wordlist brand-aware: Reolink, Hikvision, Dahua, Axis, Axis

v2.1.0 — Marzo 2026

- **Anti-falsi-positivi HTTP** — `_http_requires_auth()` testa con credenziali bogus prima del brute force; skippa se il target risponde 200/302 a tutto
- **RTSP Digest Auth nativa** — `_rtsp_digest_brute()` implementa RFC 2617 via Python3 inline (MD5 challenge-response)
- **Modulo ONVIF** — `cmd_onvif`: discovery SOAP, GetDeviceInformation, WS-Security

PasswordDigest brute force (SHA1+nonce) via curl + Python3

- **Fix RTSP snapshot** — ffmpeg primary, cvlc fallback

v2.0.0 — Marzo 2026

- Release iniziale v2: pipeline automatizzata 5 fasi, 29 subcomandi, 7 wordlist integrate
- Motore suggerimenti intelligenti (port→modulo mapping)
- Report HTML + PDF via weasyprint
- Supporto `--dry-run`, `--stealth`, `--timeout`

---

exa-dune v2.5.0 — Framework Multi-Protocollo per Penetration Testing IoT/VoIP
Piattaforma: Kali Linux 6.18 — Marzo 2026

⚠ CONFIDENZIALE — Uso esclusivamente in ambienti autorizzati ⚠

Il pentest non autorizzato è reato. Verifica sempre di avere il consenso scritto del proprietario del sistema.